

Final Exam Notes for Revision

Dear students, you may refer to this revision notes for your final exam **AT YOUR OWN RISK.**

Table of Contents

Chapter 1	2
Chapter 2.....	3
Chapter 3.....	7
Chapter 4.....	10
Chapter 5.....	11
Chapter 6.....	13
Chapter 7.....	16
Chapter 8.....	18

Chapter 1

Data vs Information

Data: A collection of facts, figures and statistics related to an object. Data can be processed to create useful information.

Information: Information is data that is **organized** and processed to give it **more meaning** and context.

Cybercrime vs Hacking

Cybercrime: An offence that involves using the Internet or a computer to carry out illegal activities, often for financial or personal gain. Examples include identity theft and social engineering.

Hacking: Hacking involves using computer expertise to gain access to a computer system without authorization. The hacker may wish to tamper with programs and data on the computer, use the computer's resources, or just prove they can access the computer.

Chapter 2

Trojan

A trojan is unique form of computer attack that allows a remote user gaining access to a victim's machine without their knowledge. It collects the information about the user behavior, credentials, and other activities on the computer silently and sends those to its command-and-control center from where the other malicious attacks can originate.

Symptoms of computer affected by the Trojan:

- Performance degrades significantly.
- Problem in Internet browsing occurs.
- Computer starts working itself without your instructions.
- Some crucial applications will stop working and unwanted applications will load without any control on them.
- Your contacts may receive emails that you did not send to them.
- Loading of computer takes much longer.

How Trojan exploit the system:

- Recording keystrokes to steal credential information.
- Commandeering user system to distribute Malware or Spam to another computer.
- Spying on user activities by sending screenshots of user monitor to a remote location.
- Uploading or Downloading files.
- Erasing or Overwriting Data.

How to prevent Trojan:

- Think before you open any attachments from emails.
- Avoid downloading programs from unsafe sources.
- Do not allow macros in Word and Excel.
- Do not click on links without thinking.
- Make regular backup of your data. Not only on cloud services, but also on a physical data carrier, such as an SSD or HDD.

Rootkit

A rootkit is a malicious software bundle designed to give unauthorized access to a computer or other software. Rootkits are hard to detect and can conceal their presence within an infected system. Hackers use rootkit malware to remotely access your computer, manipulate it, and steal data.

Symptoms of computer affected by Rootkit:

- **Your system is acting strangely:** Rootkits allow hackers to manipulate your computer's OS. If your computer is acting strangely, it could be the work of a hacker via a rootkit.
- **Change in settings:** Rootkit-enabled remote access can allow someone else to meddle with your settings and configurations. If something seems different, there might be cause for concern.
- **Web pages/network activities intermittent:** If your internet connection suddenly grows spottier than usual, it might be more than a service hiccup. If a hacker is using a rootkit to send or receive a lot of traffic from your computer, it could bog down your internet connection.

Rootkit Detection Approaches:

- **Signature scanning:** Computers do things with numbers. A software's signature is the set of numbers that serve as its representation in computer-speak. You can scan your computer against a database of known rootkit signatures and see if any of them turn up.
- **Memory dump analysis:** When your Windows machine crashes, it also generates a file called a memory dump, or crash dump. A skilled technician can examine this file to identify the source of the crash and see if it was due to a rootkit.
- **System memory search:** Search through your computer's system memory to see if anything is out of order. During the search, check all ingress (access) points for signs of invoked processes, and track all imported library calls from DLLs (Dynamic-Link Libraries). Some may be either hooked or redirected to other functions.

How rootkit is installed:

- **Dropper:** The dropper imports the rootkit onto the victim's computer. The dropper is the first stage of the installation process. When the victim activates the dropper, the dropper in turn activates the loader.
- **Loader:** As the dropper executes, the loader springs into action, installing the rootkit onto the target system. Loaders often do this by triggering a buffer overflow. This is a common security exploit that lets hackers land their code in otherwise inaccessible areas of a computer's memory.

Hackers' approach to install rootkit:

- **Hijacking messaging programs:** A blended threat can hijack instant messaging clients to spread itself to a victim's contacts. When the recipients click the malicious link in the message, their computers become infected as well. This type of social engineering attack is a highly effective method for spreading rootkits.
- **Piggybacking on trusted software:** Hackers can insert a computer rootkit into otherwise-trustworthy programs and apps, then upload those poisoned apps to various download portals. When you install the infected app, you unwittingly install the rootkit, too.
- **Using other malware:** Viruses and Trojans can be used as rootkit spreaders, because both are highly effective at getting onto your computer. When you execute the program containing the virus, or execute the Trojan, the rootkit is installed on your device.
- **Hiding in rich-content files:** With the advent of rich-content files such as PDFs, hackers no longer need to hide malware in dedicated websites or programs. Instead, they can embed rootkits into these simple rich-content files. When you open up the tainted file, the rootkit dropper executes automatically.

Rootkit Prevention:

- **Keep Software Updated:** Ensure that your operating system, applications, and firmware are regularly updated with the latest security patches. Vulnerabilities in software are often exploited by attackers to install rootkits, so timely updates are crucial.
- **Use Antivirus/Anti-Malware Software:** Deploy reputable antivirus or anti-malware solutions and keep them updated. These tools can detect and block known rootkits and other malicious software. Enable real-time scanning and automatic updates for better protection.
- **Practice Least Privilege:** Limit user privileges and access rights on systems and networks. Users should only have permissions necessary for their roles and responsibilities. This helps mitigate the impact of any successful rootkit infection.
- **Enable Firewall and Intrusion Detection/Prevention Systems (IDS/IPS):** Use firewalls to monitor and control incoming and outgoing network traffic. Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) can help detect and block suspicious activities and network-based attacks, including attempts to install rootkits.
- **Implement Secure Configuration:** Follow security best practices for system configuration and hardening. Disable unnecessary services and features, and configure access controls, authentication mechanisms, and logging to detect unauthorized access or changes.
- **Be Cautious with Email and Web Content:** Educate users about phishing attacks and malicious websites that can lead to rootkit infections. Exercise caution when clicking on links, downloading attachments, or visiting unfamiliar websites.

- **Regularly Back Up Data:** Maintain regular backups of important data and ensure backups are stored securely. In the event of a rootkit infection or other data loss incident, backups can help restore critical information without paying ransom or losing productivity.
- **Monitor System and Network Activity:** Use monitoring tools to track system and network activity for unusual or suspicious behavior. This includes monitoring log files, system performance metrics, and network traffic patterns that could indicate a rootkit infection.
- **Implement Endpoint Security Measures:** Employ endpoint security solutions that offer advanced threat detection and response capabilities. These solutions can detect and mitigate the presence of rootkits on individual devices within your network.
- **Educate and Train Users:** Raise awareness among users about the risks of malware, phishing, and social engineering tactics used to distribute rootkits. Encourage users to report suspicious activities promptly to IT or security personnel.
- **Perform Regular Security Audits and Penetration Testing:** Conduct periodic security audits and penetration testing to identify vulnerabilities and weaknesses in your systems and networks. Address any findings promptly to reduce the risk of rootkit infections.

Chapter 3

Denial-of-Service (DoS) Attack

A **Denial-of-Service (DoS) attack** is a cyberattack that floods a machine or network with false requests in order to disrupt business operations. In a DoS attack, users are unable to perform routine and necessary tasks, such as accessing email, websites, online accounts or other resources that are operated by a compromised computer or network.

Type of DoS Attacks:

- Buffer Overflow: crash web-based services
- Flood Attack: flood infrastructure with bogus requests

How to identify DoS:

- Slow network performance for common tasks, such as downloading/uploading files, logging into an account, accessing a website or streaming audio or video content.
- Inability to access online resources, including websites or web-based accounts, such as bank accounts, investment portfolios, education materials or health records.
- An interruption or loss in connectivity of multiple devices on the same network.

Distributed Denial-of-Service (DDoS) attack

DDoS attack is considered to be more sophisticated and poses a much larger threat to organizations because it leverages multiple devices across a variety of geographies, making it more difficult to identify, track and neutralize. Most commonly, DDoS attackers leverage a botnet, which is a network of compromised computers or devices that are supervised by a command and control (C&C) channel.

DDoS Motive:

- **Financial Motives:** DDoS attacks are often combined with ransomware attacks. The attacker sends a message informing the victim that the attack will stop if the victim pays a fee. These attackers are most often part of an organized crime syndicate. Today, though, these syndicates can be as small as a dozen individuals with networking knowledge and extra time on their hands. Sometimes, rival businesses will even conduct DDoS attacks on each other to gain a competitive edge.
- **Ideological Motives:** Attacks are often launched to target oppressive governing bodies or protestors in political situations. A DDoS attack of this kind is often conducted to support a particular political interest or belief system, such as a religion.
- **State-sponsored Motives:** DDoS attacks are often waged to cause confusion for military troops or civilian populations when political unrest or dissension becomes apparent.
- **Tactical Motives:** In this case, the DDoS attack is waged as part of a larger campaign. In some cases, the campaign includes a physical attack or another series of software-based attacks. For example, militaries have been known to combine DDoS attacks with physical ones. Tactical attacks are used to divert attention away from normal IT tasks to take advantage of a different target – the old bait-and-switch cyberattack.
- **Business/Economical Motives:** DDoS attacks of this variety help to gather information or cause damage to particular industry sectors. For example, attacks on companies such as Sony, British Airways and Equifax caused consumers to lose faith in entire industries.
- **Extortion Motives:** Other attacks are used to attain some personal or monetary gain through extorted means.

How to reduce the risk of a DoS attack:

- Reduce Attack Surface Area
- Load balancing
- Web application Firewall used to filter and monitor HTTP traffic
- Use multiple ISP connections

Social Engineering

The use of persuasion on human users in order to gain information required to access a system. The main objective of such social engineering attacks is to achieve the financial benefits from the unsuspecting people.

Social Engineering Techniques:

- **Pretexting:** This involves creating a fictional scenario or a convincing pretext to gain the target's trust, usually posing as an authority figure. For example, an attacker might pretend to be a bank representative seeking verification of account details.
- **Baiting:** Attackers use baiting to tempt potential victims into taking specific actions. For example, a hacker might leave a malware-infected USB drive in an office, hoping that someone would plug it into a computer and trigger the infection.
- **Tailgating** or piggybacking: Attackers follow closely behind an authorized employee into a restricted area, effectively bypassing entry control measures such as card scanning or PIN entry.
- **Quid pro quo:** In this method, the attacker offers help or assistance in exchange for sensitive information. For example, a hacker might offer free technical support and, in the process, ask for passwords or other confidential information.

Chapter 4

Potential risks associated with using an unprotected wireless network:

Aspect	Eavesdropping	Network Hijacking	Man-in-the-Middle (MITM) Attack
Definition	Unauthorized monitoring of data over a network	Gaining control of an active session or network communication	Intercepting and possibly altering communication between two parties
Passive or Active?	❄️ Passive (usually)	🔥 Active	🔥 Active
Goal	To secretly collect sensitive information (e.g., passwords, messages)	To take over a session or redirect traffic	To intercept, observe, or manipulate communication without detection
How It Works	Attacker listens in on unencrypted traffic using sniffing tools	Attacker seizes or redirects a live connection (e.g., DNS spoofing, session hijacking)	Attacker sits between two parties and relays or alters messages, pretending to be both
Main Tool Used	- Packet sniffers (e.g., Wireshark) - Network taps	- Session hijacking tools - DNS spoofing tools - ARP spoofing	- ARP poisoning tools - SSL stripping tools - Rogue Wi-Fi APs
Impact	- Data leakage - Privacy violation	- Unauthorized access - Session manipulation - Redirection to fake resources	- Data tampering - Identity theft - Credential theft
Real-World Examples	- Sniffing passwords on public Wi-Fi - Capturing HTTP traffic	- DNS hijack redirecting users to phishing site - Cookie/session token theft	- ARP spoofing on LAN - Evil Twin AP on public Wi-Fi - HTTPS to HTTP downgrade
Countermeasures	- Use encryption (HTTPS, SSL, VPN) - Avoid public Wi-Fi for sensitive data	- Use HTTPS and secure sessions - Implement DNSSEC - Use secure cookies	- SSL/TLS certificates - Mutual authentication - VPNs - Network segmentation

Firewall

Firewalls are the defense wall of the corporate network connected to the Internet. The firewall is normally connected after edge router inside the local network. This device protects the internal devices from the malicious intrusion of unauthorized users. Firewall is able to detect any untrusted connection and stop it from intruding into the security measures of the system.

The roles of firewall:

- Protect sensitive data and resources from unauthorized access by preventing unauthorized connections.
- Block or allow specific applications and services based on security policies or rules.
- Monitor and log traffic on the network for auditing and troubleshooting purposes.
- Prevent or mitigate certain types of cyberattacks like Distributed Denial of Service (DDoS) attacks, intrusion attempts, and malware infections.

Types of firewalls:

- Software Firewall
- Hardware Firewall

Chapter 5

Benefits of HTTPS

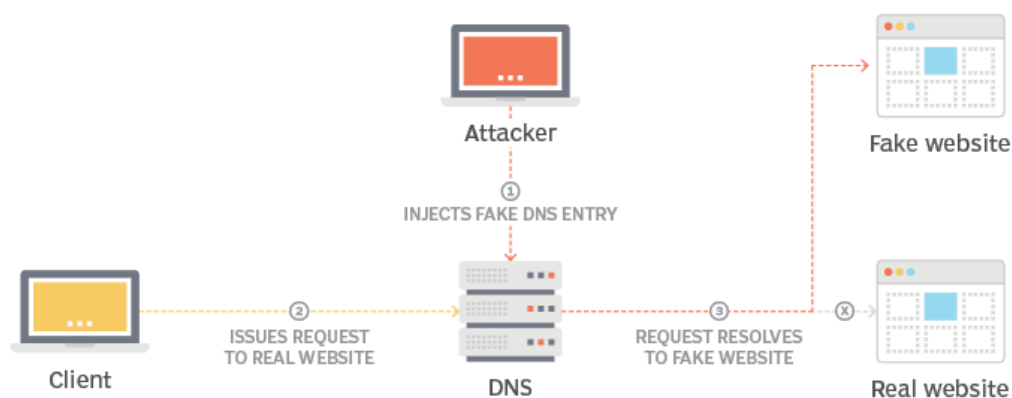
- **Data Protection:** The encrypted communication prevents unauthorized third parties from intercepting and reading user data.
- **Authentication:** SSL certificates assure users that they are communicating with a legitimate website, reducing the risk of phishing attacks.
- **Improved SEO:** Search engines like Google prioritize websites with HTTPS and SSL, offering higher search rankings and increased visibility.
- **Increased Trust:** Users are more likely to trust and share personal information on websites that display the HTTPS padlock symbol, leading to better user engagement and potentially higher conversion rates.
- **Compliance:** Some industries, such as finance and healthcare, have regulations that mandate the use of HTTPS and SSL to protect user data.

Pharming

Pharming is a type of cyber-attack where attackers inject malicious code to redirects users from legitimate websites to fraudulent, spoofed versions to steal their sensitive information, such as login credentials or financial data. Unlike phishing, which relies on tricking users via deceptive links, pharming automatically redirects users by manipulating DNS (Domain Name System) settings or by installing malware on their devices.

How Pharming is conducted:

1. A pharming attack is an attack in which malware redirects the victim to a malicious version of a website.
2. The malware could infect the victim's computer or the DNS server.
3. When the victim enters a web address into their browser, they visit a website controlled by the attacker, rather than the legitimate website.
4. The attacker can then collect any data that the victim inputs into the website.



Indication of Pharming Attack:

- Spelling errors or incorrect logos
- Broken or missing links
- A notification from your browser warning you that the webpage is insecure
- The lock symbol that your browser uses to confirm that a webpage is secure is missing

Web Application Firewall

A Web Application Firewall (WAF) is a security solution that helps protect web applications from malicious attacks, intrusions, and data breaches.

It filters, monitors, and blocks web traffic based on a set of predefined rules to counter common web exploits, such as Cross-Site Scripting (XSS), SQL Injection, and Cross-Site Request Forgery (CSRF) attacks.

The primary purpose of a WAF is to act as a shield between the internet and the application layer. It does this by intercepting and monitoring real-time HTTP/HTTPS traffic, identifying and blocking malicious requests before they reach the web server, and preventing unauthorized access to sensitive data.

Chapter 6

Instant Messaging

Instant messaging (IM) refers to a real-time communication method that allows users to exchange text messages, multimedia files, and other forms of data over the internet. It enables instantaneous interaction between individuals or groups using various devices such as computers, smartphones, and tablets.

Instant Messaging Key Features:

1. **Real-Time Communication:** Instant messaging facilitates immediate and synchronous communication between users. Messages are typically delivered and received instantly, allowing for rapid exchange of information.
2. **Text-Based Messaging:** The primary mode of communication in instant messaging is text messages, which can include emojis, stickers, and multimedia attachments such as images, videos, and documents.
3. **Group Messaging:** Instant messaging platforms often support group chats or group messaging, allowing multiple participants to engage in conversations simultaneously. This feature is useful for team collaboration, social groups, or event planning.
4. **Presence Status:** Users can typically see the online/offline status of their contacts, indicating whether they are currently available for communication.
5. **Read Receipts and Typing Indicators:** Many instant messaging apps provide read receipts to indicate when a message has been read by the recipient. Typing indicators show when someone is actively composing a message.
6. **Voice and Video Calling:** Some instant messaging platforms offer voice and video calling capabilities, allowing users to have voice conversations or video conferences directly within the app.
7. **Encryption and Security:** To protect user privacy and data security, many instant messaging services use end-to-end encryption (E2EE) for messages and calls. This ensures that only the sender and intended recipient can access the content.
8. **Integration with Other Services:** Instant messaging apps may integrate with other services and platforms, such as file sharing services, social media, or productivity tools, to enhance functionality and user experience.

Examples:

WhatsApp, Telegram, Slack, WeChat

Uses and Benefits of Instant Messaging:

- **Instant Communication:** Facilitates quick and efficient communication, reducing the need for formal emails or phone calls.
- **Collaboration:** Supports teamwork and collaboration among colleagues, allowing for real-time discussions, file sharing, and project updates.
- **Personal Communication:** Enables individuals to stay connected with friends and family regardless of geographical distance, fostering personal relationships.
- **Business Communication:** Used for customer support, sales outreach, and internal communications within organizations, enhancing productivity and responsiveness.

VoIP

VOIP (Voice over Internet Protocol) is a technology that enables voice communications and multimedia sessions over the Internet Protocol (IP) networks. It essentially allows you to make phone calls using the internet rather than traditional telephone lines.

VoIP Key Aspects:

- **Digital Transmission:** VoIP converts voice signals into digital data packets, which are then transmitted over IP networks (like the internet).
- **Cost-Effective:** VoIP often costs less than traditional phone services, especially for long-distance and international calls, as it utilizes existing internet connections.
- **Features:** VoIP services can offer a wide range of features beyond traditional telephony, such as video conferencing, instant messaging, file sharing, and more.
- **Flexibility:** VoIP systems can be used on various devices like computers, smartphones, and specialized VoIP phones, allowing for mobility and remote work capabilities.
- **Integration:** VoIP can integrate with other digital services and applications, such as CRM systems, collaboration tools, and customer support platforms.

VoIP Security Concerns:

- **Malware** – malware can target specific IM applications in order to spread themselves.
- **Backdoor access** – Access to your systems may be allowed by vulnerabilities in IM and VoIP that allow security measures such as a firewall to be bypassed.
- **Access to files** – some virus that spread through IM may enable file sharing on a computer, allowing a hacker to gain full access.
- **Eavesdropping** – IM and VoIP can be susceptible to monitoring unless it is encrypted.

Strategies to ensure confidentiality when using VOIP and IM:

- Encryption
 - Best solution to ensure the security and privacy
- Non-disclosure of important details
 - Refrain from disclosing personal and sensitive details over IM or VoIP. This may give a hacker access to privileged information.
- Restricting file sharing
 - Avoid sharing files over an IM network as these can be intercepted.

Chapter 7

Cloud Services

A cloud service refers to any resource or application that is provided over the internet by a cloud computing provider. These services are typically delivered on-demand, often through a subscription-based model, and can include a wide range of functionalities and capabilities.

Types of Cloud Services:

- **Infrastructure as a Service (IaaS):** Provides virtualized computing resources over the internet, such as virtual machines, storage, and networking.
- **Platform as a Service (PaaS):** Offers a platform allowing customers to develop, run, and manage applications without needing to manage underlying infrastructure.
- **Software as a Service (SaaS):** Delivers software applications over the internet on a subscription basis, eliminating the need for users to install and maintain software locally.

Cloud Services Benefits:

- **Scalability:** Cloud services can scale resources up or down based on demand, offering flexibility and cost-efficiency.
- **Accessibility:** Users can access cloud services from anywhere with an internet connection, promoting remote work and collaboration.
- **Reliability and Availability:** Cloud providers often offer robust infrastructure with redundancy and high availability, minimizing downtime.
- **Security:** Cloud services typically include built-in security measures such as encryption, firewalls, and access controls to protect data.

Examples of Cloud Services:

- **Storage Services:** Cloud storage providers like Amazon S3, Google Cloud Storage, and Microsoft Azure Blob Storage offer scalable and reliable storage solutions.
- **Compute Services:** Providers such as Amazon EC2, Google Compute Engine, and Microsoft Azure Virtual Machines offer scalable compute resources.
- **Database Services:** Managed database services like Amazon RDS, Google Cloud SQL, and Azure SQL Database provide scalable and reliable database solutions.

Physical Security

- **Do not leave unsecured computers or devices unattended:** This particularly applies to easily stolen mobile devices, such as laptops, smartphones, and tablets, which you may be using in a public environment.
- **Log equipment location and details,** for example PCs. This allows for equipment to be tracked easily.
- **Use cable locks** to secure computers and devices safely, especially if members of the public have access to the work area.
- **By using access control measures,** such as swipe cards or biometric scanning. This will prevent unauthorized individuals from accessing the workplace.

Backup Procedures

- **Schedule** Whenever possible, schedule backups during off peak hours. When system use is low, the backup process takes less time to complete. You will need to carefully plan when to back up key system data.
- **Compression** Compressing data during a backup helps reduce the size of files so that they can be stored using less memory than the original file(s). Upon decompression the files will return to their original size.
- **Location** To ensure that backups are not lost in case of natural disasters, it is essential that copies of backups are stored off-site. You will also need to include copies of all software you need to install to recover and re-establish system operations.
- **Regularity** How often you create backups depends on the value of the data and the frequency with which the data changes. For example, if your data changes on a daily basis, a daily backup may be performed.

Reasons to have backup procedures:

- One way to avoid loss of important data is to regularly create backups of the data.
- Important data could be lost due to accidental or malicious deletion, power surges, disk corruption, or physical damage from fires or flood.
- The backed-up data should be stored separately from the original data. Ensure that if some form of physical disaster damages the originals, the backups will be in a safe location.

Chapter 8

Securing an Organization's Sensitive Information

- Network Security
 - Configure firewalls to block unauthorized access to your network.
 - Segment networks to prevent unauthorized access to sensitive information.
 - Implement strong passwords to prevent unauthorized access to your network.
 - Limit network access to authorized personnel only.
- User Education & Awareness
 - Train employees on how to identify and report suspicious activities and phishing emails.
 - Conduct regular training and awareness campaigns to reduce the risk of human error.
 - Establish policies and procedures for reporting incidents.
- Malware Prevention
 - Implement anti-virus software to detect and prevent malware infections.
 - Apply security updates and patches regularly to prevent known vulnerabilities.
 - Avoid downloading files from untrusted sources to prevent malware infections.
- Removable Media Controls
 - Establish policies and controls for using removable media, including encryption and antivirus scanning.
 - Restrict access to removable media to authorized personnel only.
 - Regularly scan removable media for malware infections.
- Secure Configuration
 - Configure hardware and software systems to be secure by default.
 - unnecessary services to reduce the attack surface.
 - Remove default accounts and passwords to prevent unauthorized access.
- Managing User Privileges
 - Assign access rights based on the user's job requirements.
 - Implement least privilege principles to limit access to sensitive data and systems.
 - Regularly review and update user privileges.
- Incident Management
 - Develop a plan to respond to cybersecurity incidents effectively.
 - Identify and report incidents to appropriate personnel.
 - Assess the impact of incidents and contain the damage.
- Monitoring
 - Continuously monitor systems, networks, and data for suspicious activities or anomalies.
 - Analyze log files, network traffic, and system performance metrics to identify potential threats.

- Regularly review and update monitoring policies and procedures.
- Home & Mobile Working
 - Establish policies and controls for securing home and mobile working environments.
 - Use secure connections to prevent unauthorized access to sensitive information.
 - Encrypt sensitive data to prevent unauthorized access.
- Cybersecurity Governance
 - Establish policies, procedures, and controls to manage cybersecurity risks effectively.
 - Conduct regular risk assessments to identify potential threats.
 - Regularly audit and report on compliance with cybersecurity standards.